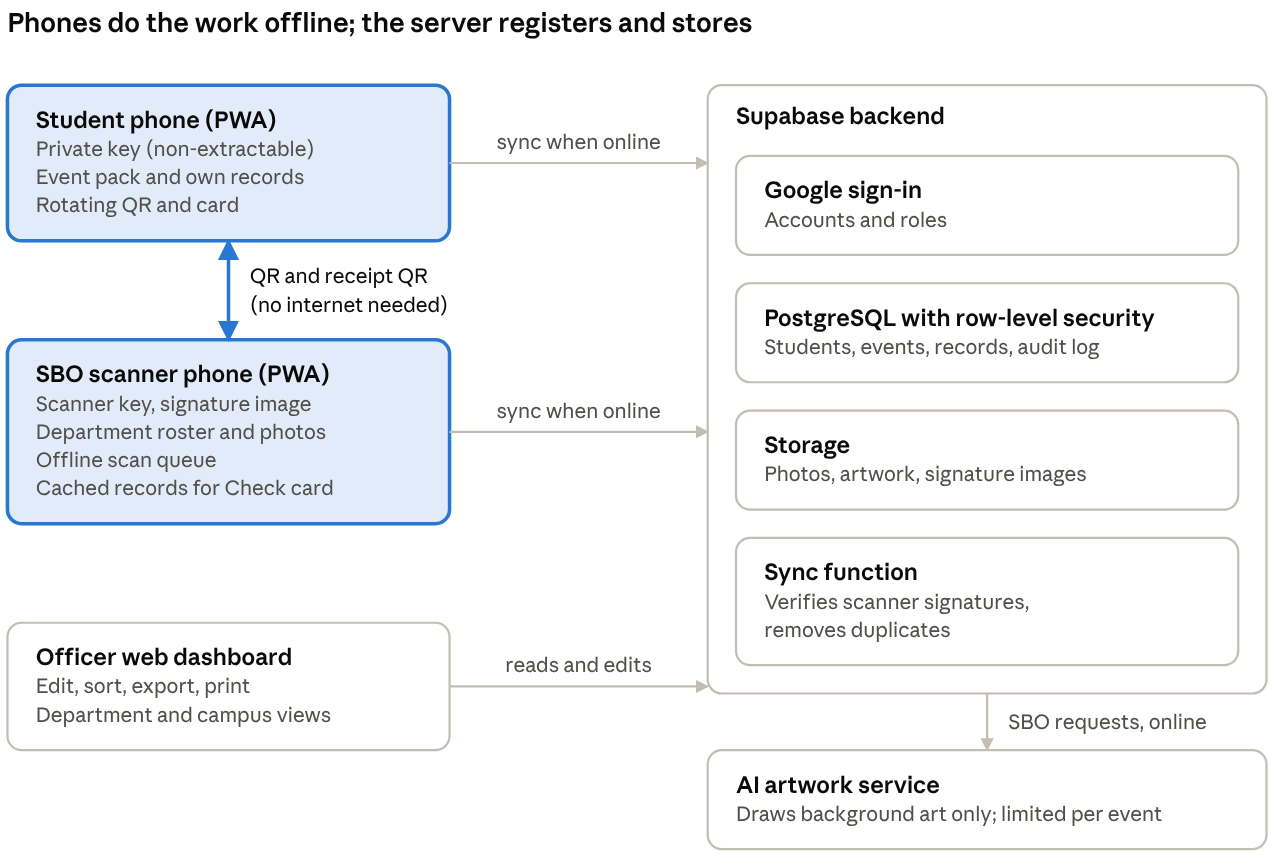
4. System Design — TCC Event Clearance App

Nov 8, 2026 · @rogiie

The app is offline-first: phones hold the data and the cryptographic keys they need, and the server only registers users, stores events and receives scans when a connection is available.

Architecture overview



architecture · 3 clients, 1 backend, 1 external service

Phones hold the keys and data they need, so the QR and the scanner work offline and sync to the backend when a connection exists. The AI service is called only by officers, and only online.

Identity and the rotating QR

The QR is a short-lived signed message from the student's phone, which the scanner can verify with no internet.

1. At registration the phone generates an ECDSA P-256 key pair with the browser's WebCrypto API. The private key is marked non-extractable and stays in the phone's IndexedDB. The public key goes to the server and is bound to the student after approval.
2. The QR payload holds the student ID, event ID, a 30-second time window, a random nonce and, only when the event requires it, the phone's coordinates. The phone signs it with the private key. The payload is about 100 bytes, so the QR stays small and scans fast.
3. The scanner's roster pack already contains each eligible student's public key, so it checks the signature, the time window (with a small tolerance for clock drift), the event and eligibility, then shows the photo.
4. A scanner never holds anything that can forge a student's QR; this is why the design uses key pairs and not a shared secret.
5. A student can have one valid check-in per slot. The scanner remembers accepted pairs, and the server enforces the same rule with a unique constraint.

A screenshot expires within about a minute. A live relay (a friend streaming the QR) is the case the photo comparison at the scanner exists to catch.

Stamps and card integrity

A card is valid because a signed record exists, never because the picture looks right. AI can copy a signature image, a seal and a timestamp, but it cannot create a record.

1. **Per-scanner keys.** Each scanner phone has its own ECDSA key pair, registered with the server when the officer signs in. A lost phone is revoked individually.
2. **Signed records.** When the SBO accepts a student, the scanner builds a record (student, event, slot, venue, time, officer, method, serial number) and signs it with its key.
3. **Server check.** On sync the server verifies each signature against the registered scanner key before storing the record.
4. **Rendering.** The stamp on the card is drawn from stored records: the officer's saved signature image, the printed name and position, the time and the serial number.

5. **Check card.** The SBO screen reads the records (from the server, or from cached records when offline) and shows each slot as signed or missing. The QR on the card carries only a card identifier.
6. **Receipt QR (optional).** After accepting, the scanner can show a QR holding the signed record. The student's phone verifies it with the scanner's public key from the event pack and draws the stamp at once.

If a copied or AI-edited card is shown, the Check card screen simply finds no matching records.

Offline-first data and sync

Device	Stored locally	Refreshed
Student phone	Private key, profile, event packs, own attendance records	At each sync and event pack download
Scanner phone	Scanner key, officer's signature image, event pack, department roster with photos and public keys, local scan queue, cached attendance for Check card	Before each event and whenever signal returns

Sync rules

1. Every scan is saved locally first with a client-generated UUID and queued.
2. The queue uploads in batches when a connection exists. The scanner shows "X scans waiting to sync".
3. The server verifies signatures and removes duplicates: for one student and slot the earliest scan wins and later ones are marked duplicate.
4. A signed scan is never overwritten. Dashboard edits are stored as separate logged changes.
5. The server tells devices when an event changed, and they show "event updated, please sync".
6. On iPhone, sync runs only while the app is open, so the counter must stay visible.
7. "Export backup" writes the unsynced queue to a file so no attendance is ever lost.

Capacity and scale

All figures are estimates from the numbers you gave (about 6,000 students, 8 departments) and need a pilot to confirm.

Item	Estimate
Students	About 6,000
Largest department	CCJPS, about 10 sections, roughly 1,000 to 1,500 students
Records per day	Up to 6,000 per slot, so up to 24,000 with four slots
Records for a 5-day event	Up to about 120,000 rows, which is small for PostgreSQL
Roster pack, largest department	About 10 to 25 MB (a 160 px thumbnail is roughly 10 to 15 KB)
Photo storage	About 0.3 GB for 6,000 students (one thumbnail and one larger photo each)
Scanner speed	600 to 1,000 students per hour, so two scanners handle 1,500 students in about an hour at worst, less when arrivals are staggered
Event pack per student	Keep under 150 KB by compressing artwork; at 6,000 students that is about 0.9 GB of download per event

Server load is a burst of uploads after each event, not live traffic, because scanning never waits on the server. Download bandwidth for event packs is the cost to watch; check the hosting plan's current limits before the event.

Security and data privacy

- **Access control.** Row-level security in the database: a student reads only their own data, a department officer reads their own department, a head officer reads everything. Scanners write attendance only through a function that verifies the scanner's signature.

- **Minimal data.** Store name, school ID, department, year level, section, Google email and photo. Store the location result (distance and flag), not a trail of raw coordinates. Read location only when the student opens a QR for an event that requires it.
- **No registrar data.** Students supply their own details and the department SBO approves them.
- **Consent and retention.** A consent screen at registration states what is collected and why. Photos and scan logs are deleted or archived at the end of the school year. Brief the school's data protection officer under the Data Privacy Act (RA 10173).
- **Audit log.** Every scan, rejection, manual check-in, reset, edit and publish records who, what and when.
- **Transport and keys.** HTTPS only; private keys are non-extractable and never leave the phone; a lost scanner key is revoked.
- **Abuse limits.** A cap on AI artwork regenerations per event and rate limits on sign-in and sync.